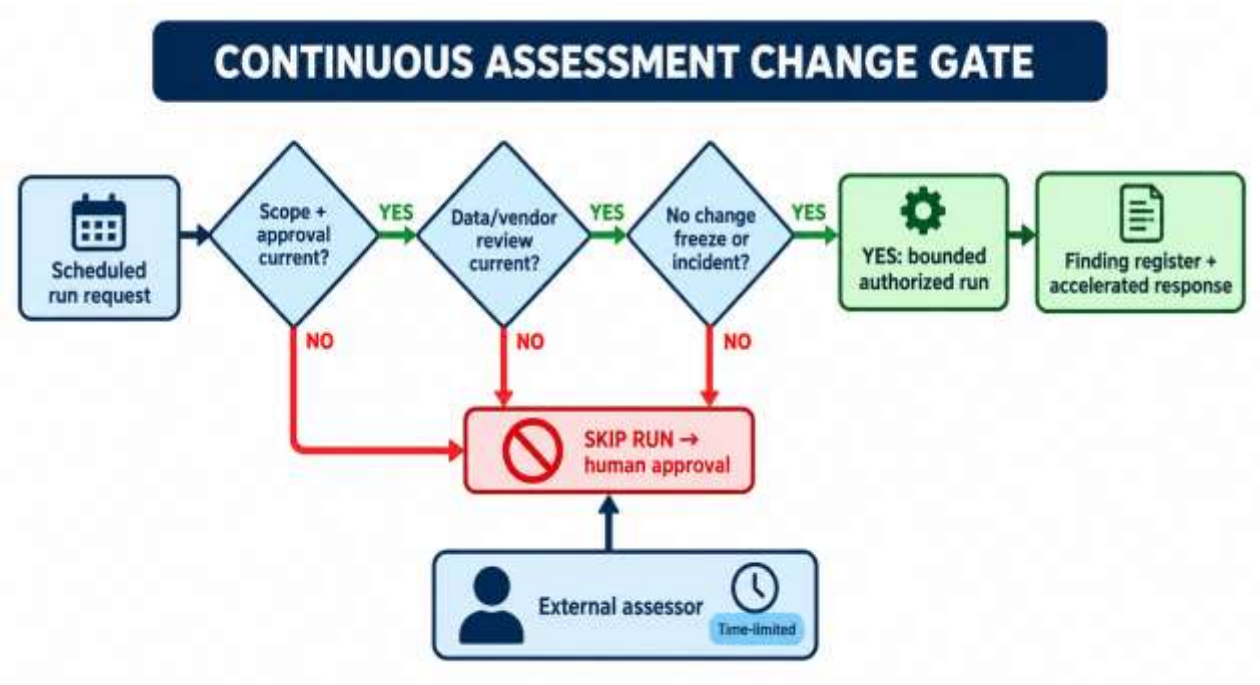
CO1 | ASSIGNMENT 1

Ethical Hacking Engagement Governance Framework

Executive summary

This design governs authorized assessments of the university portal, LMS, email and campus network, initially about 20 systems and 50 staff, with a path to university-wide and third-party work. No assessment starts without current written authority and exact scope. Data is minimized, testing is bounded, and findings follow controlled disclosure. Authorization, legality and appropriateness are independent checks; all must pass. Hands-on work stays in an isolated lab.

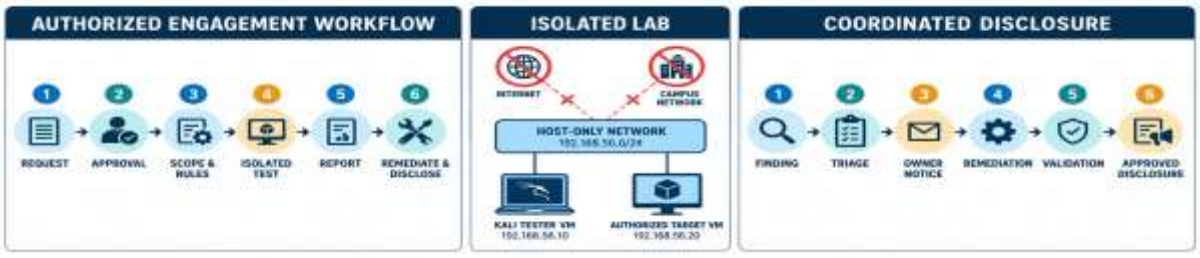


FLOW	FLOW	FLOW	FLOW	FLOW	FLOW
REQUEST	APPROVE	SCOPE	TEST	REPORT	REMEDIATE

Task 1 Enquiry and framework blueprint

Need	Response / evidence
Systems	Inventory with asset IDs, owners, environments, dependencies.
Stakeholders	Sponsor, owner, security lead, privacy/legal reviewer, tester.
Constraints	Written authority, scope, time window, data minimization, stop plan.
Enquiry	Who approves? What is in scope? Which laws apply? How are findings disclosed?
Acceptance	Traceable scope; least data; contained lab; accountable owners; timely response; scalable forms.

FLOW	FLOW	FLOW	FLOW	FLOW	FLOW
Request + owner	Authority + legal/privacy	Signed RoE	Bounded test	Report + remediate	Disclosure

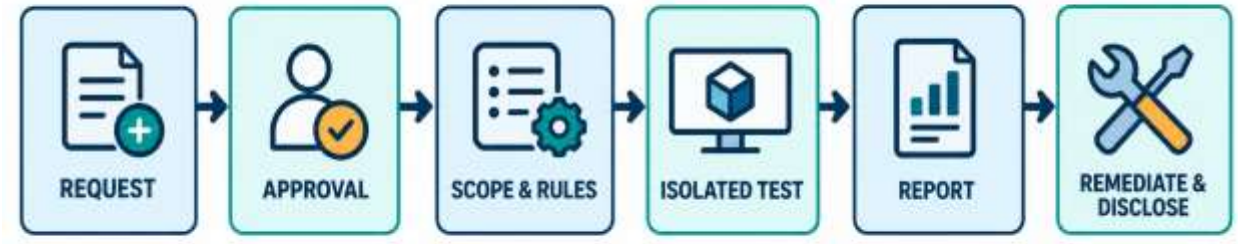


Task 2 Hacker threat model and classification

Type	Motivation / capability	Targets

White hat	Authorized defence; structured testing	Listed systems
Black hat	Profit/extortion; credential theft	Student data, payroll, email
Grey hat	Curiosity; may probe without consent	Public portals
Script kiddie	Attention; reused tools	Login, Wi-Fi
Hacktivist	Cause/publicity; disruption	Public sites/email
Insider	Gain/grievance/error; role access	Records/admin tools
State-sponsored	Strategic; patient and resourced	Research, identity, email

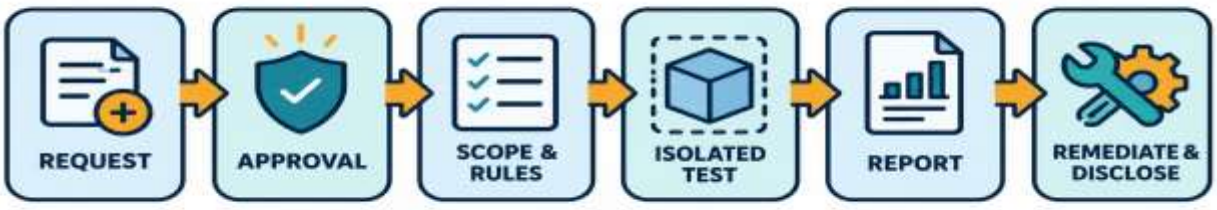
Borderline case: an unaffiliated researcher finds exposed data, stops and reports privately. “Grey hat” fits because initial probing lacked permission; “responsible researcher” describes later restraint. Record both facts as “unauthorized initial access; cooperative reporter.” Helpful reporting does not retroactively authorize access.



Task 3 Ethics and code of conduct

Principle	Rule and scenario response
Written authority	Verify signed ID, exact assets, methods, dates and approvers.
Scope / no harm	Match target; stop at redirects; rate-limit; no destructive or denial-of-service methods.
Privacy / integrity	Use synthetic evidence; encrypt; do not alter or bulk-copy records.
Honesty / disclosure	Report limits and false positives through secure channel only.
Acceptable	Listed staging host and supplied test account: log and report.
Borderline	Unlisted vendor redirect: pause and obtain consent.
Unacceptable	Download real student data: stop, protect, notify incident/privacy contacts.

Decision rule: if target, method, timing or data treatment is unknown or unapproved, pause and contact the test lead.



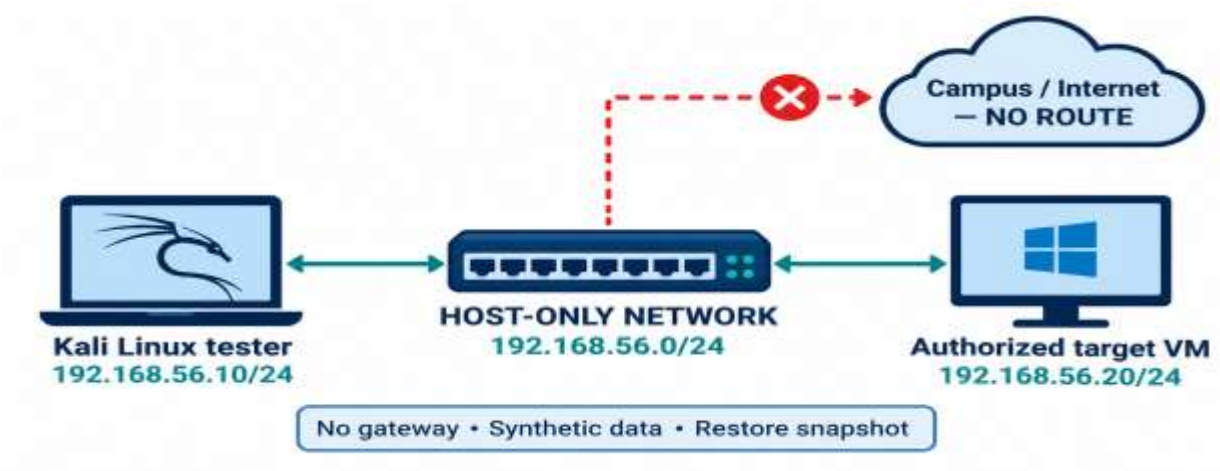
Task 4 Legal-compliance mapping

India is the primary context. The DPDP Act has staged commencement; a November 2025 notification schedules different provisions over time. At 2 November 2026, confirm the exact provisions effective on the engagement date. CFAA is comparative; U.S. nexus requires counsel review.

Law	Relevance / consequence	Control
ITA §43	Unauthorized access, copying, damage or disruption may create compensation liability.	Written exact scope; no unapproved copy/disruption.
ITA §66	Dishonest/fraudulent §43 conduct: up to 3 years, ₹5 lakh, or both.	Approval is not blanket immunity; stay within lawful scope.
ITA §§72/72A	Confidentiality and contractual disclosure offences may apply; §72A can carry up to 3 years/₹5 lakh.	NDA, least privilege, restricted evidence.
DPDP Act	When provisions apply: safeguards, breach duties, penalties vary.	Privacy review, minimization, encryption, incident plan; verify commencement.
CFAA 18 USC §1030	Specified unauthorized access/damage under U.S. law.	No cross-border test without owner/provider approval and counsel.

For personal data: record data type, roles, location, processor terms and applicable provisions. Default to no production data; if necessary, document need, minimize, restrict, encrypt, delete on

schedule and define incident contacts. This is a selected-provision academic mapping, not legal advice.

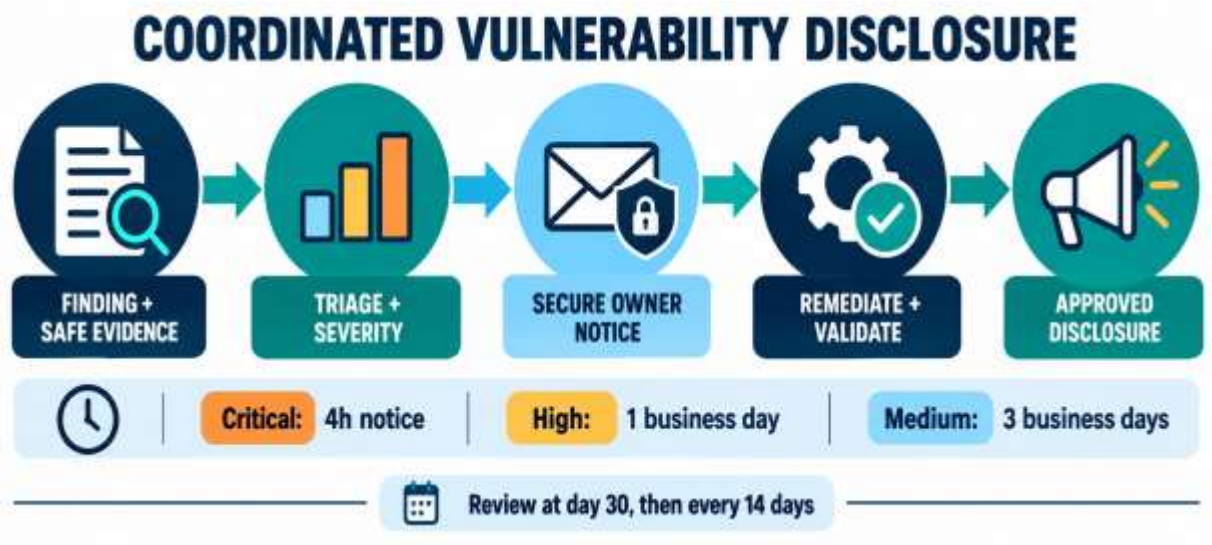


Task 5 Scope and rules of engagement

RoE field	Required contents
In/out scope	Exact asset ID, host/IP, environment, owner, dependencies; explicitly list exclusions.
Window / methods	Start-end; allowed review and safe checks; prohibited persistence, DoS, data extraction.
Safety	Rate limits, backups, rollback, stop thresholds, emergency contacts.
Data	Minimization, secure store, recipients, retention/deletion.
Approval	Sponsor, owner, security; privacy/legal/vendor as triggered.

Verify signer authority. Bind approval to exact assets, methods, dates, tester IDs and source addresses. Wildcards and redirects do not authorize adjacent systems. Changes create a new approved RoE; unsigned, expired, conflicting or revoked permission blocks work.

Checklist	Evidence / fail action
Authority active	Signed record; else block.
Target and method listed	Exact match; else do not probe.
Data and safety ready	Synthetic account, rollback, contacts; else reschedule.
Disclosure path	Named recipients, secure channel and SLA; else escalate.



Task 6 Authorization and disclosure layer | 5 marks

FLOW	FLOW	FLOW	FLOW	FLOW	FLOW
Request	Owner validation	Risk review	Privacy/legal/vendor	Sign + register	Activate

Trigger	Approval
Vendor/shared hosting	Provider and university owner

Personal data	Privacy officer and counsel as needed
Production/high impact	Owner, security, change manager
External assessor	Contract, NDA, identity/access check
Cross-border/U.S. link	Counsel and relevant provider

Register immutable approval ID, signers, RoE version, status and expiry. Start only after all gates pass. Coordinated disclosure is default: critical notice within 4 hours, high within 1 business day, medium within 3 days; remediation targets are 1, 5 and 10 business days respectively. Review disclosure at day 30 and every 14 days. These are proposed internal targets, not statutory safe harbors. Full disclosure requires harm, legal and communications review. A bug bounty needs explicit scope and safe-harbor terms and never authorizes out-of-scope work.



Task 7 Isolated ethical-hacking lab

FLOW	FLOW	FLOW
Kali VM 192.168.56.10	HOST-ONLY 192.168.56.0/24; no gateway	Target VM 192.168.56.20

Component	Control
Kali	Static .10/24; no bridged/NAT adapter during testing.
Target	Authorized training image, synthetic data, disposable snapshot.
Network	Host-only; no default route or campus/public connection.
Record	VM/image hashes, adapter, routes, firewall, snapshot, verification.

Operation A: record configuration and snapshot identifiers. Operation B: verify connectivity only to target and confirm no campus/public route. Restore snapshots after exercise. Host-only offers containment and is selected; NAT simplifies updates but permits outbound traffic, so updates occur only with targets off and the network is disconnected before assessment.



Task 8 Reusable document library

Template	Fields / integration

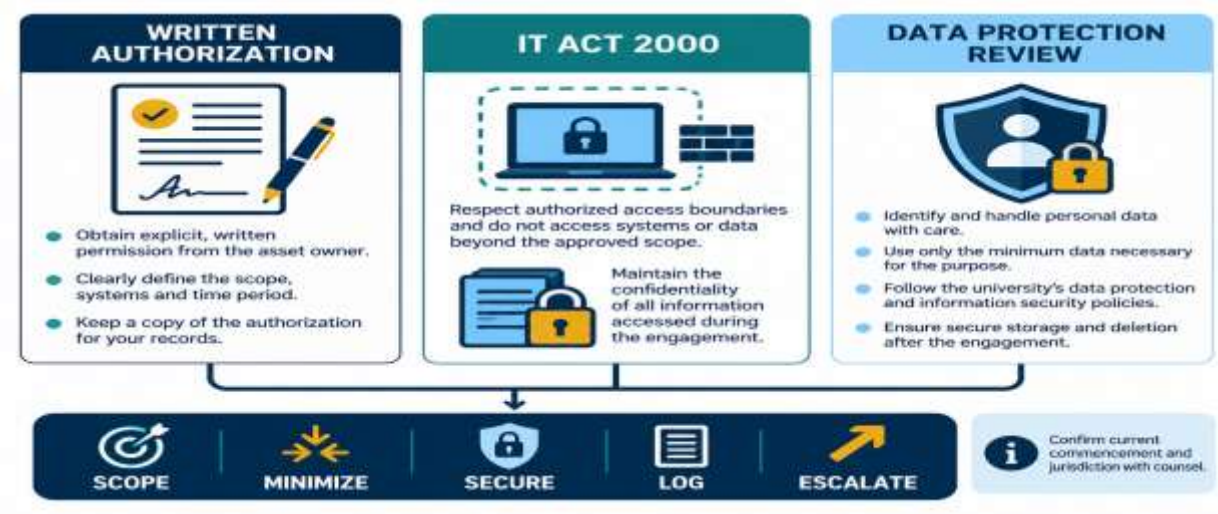
Authorization request	ID, purpose, requester, exact assets, methods, dates, data, risk, approvals, signatures, expiry; activates RoE.
Scope and RoE	In/out assets, methods, limits, window, contacts, safety, privacy, change log.
Finding report	Finding/engagement/asset IDs, severity, confidence, redacted evidence, impact, fix, owner, due date, status; feeds register.
Closure certificate	Accounts disabled, evidence disposition, exceptions, residual risk, lessons.

Structured finding fields and test entries

Field	Rule	Sample
finding_id	Unique required	F-2026-014-01
engagement_id / asset_id	Must exist and match active scope	UH-SA-014 / LMS-STG-01
severity / confidence	Critical-Informational / Confirmed-Likely-Unconfirmed	High / Confirmed
evidence_ref	Restricted vault; no raw personal data	vault://.../evidence-01
owner / due / status	Owner and ISO date for High+; controlled enum	LMS owner / 2026-11-09 / Notified

Input case	Expected result

Valid active engagement, in-scope asset, redacted evidence	Accept, assign ID, notify owner within SLA.
Boundary: Medium and due date at deadline	Accept with reminder and redaction review.
Invalid ID, out-of-scope asset, unknown severity or raw student record	Reject/quarantine; alert governance; handle attachment under incident process.



Task 9 Integrate, test and refine

Step	LMS walkthrough	Gate / record
Request	Owner requests staging assessment	UH-SA-014; IDs confirmed.
Authorize	Risk triage; synthetic accounts; provider consent for identity endpoint	Signed RoE; endpoint excluded if consent absent.
Prepare	Check window, account, limits, rollback, contacts, lab	Checklist passes.

Test	Review config; lab reproduction with synthetic records	Stop at unexpected data or boundary.
Report	Structured finding with redacted evidence and owner	F-2026-014-01 in restricted register.
Fix / validate	Owner patches; approved narrow retest	Status and fix evidence logged.
Close / disclose	Remove access; certificate; coordinated notice only if needed	Decision and rationale logged.

Test case	Expected behavior	Refinement
Missing approval	Block start	Session-start register check.
Out-of-scope redirect	Pause and request owner/provider permission	RoE requires dependency list and reapproval.
Legal/data conflict	Pause; privacy/counsel select safer proof or cancel	Gate added for personal data/cross-border.
Delayed disclosure	Escalate; review every 14 days; consider harm and controls	Named decision owner and next review date.
Service degradation	Stop; notify incident contact; recover	Mandatory thresholds and rollback contact.

Walkthrough refinement: the first draft did not distinguish a university account from vendor infrastructure. The final RoE requires dependency ownership and consent. Expiry is now explicit, and closure verifies account removal.

Task 10 Scalability and governance evaluation

Planning estimates below are scenario comparisons, not measurements from live testing. They are reproducible by applying the same workflow to the stated programme sizes.

Measure	Small department	Whole university	Interpretation
Scale	3 systems; 5 testers	~200 systems; 50+ staff and external assessors	Use central asset IDs and delegated owners.
Approval turnaround target	3 business days; 4 steps	7 business days; 6 gated steps	Parallelize review; keep mandatory gates.
Scope coverage	All 3 requested assets	≥95% inventory validated before start	Coverage = validated / requested, exceptions tracked.
Finding handoff	6 steps	8 steps	Privacy/vendor and communications add coordination.
Assessors	0–1 external	Multiple, named assessors	Time-bound access and quarterly recertification.

Process comparison

Process	Small	Large
Approval steps	■■■■ 4	■■■■■■ 6
Finding handoff	■■■■■■ 6	■■■■■■■■ 8
Coverage	100% of 3	≥95% before test

Governance refinement: centralize records, parallelize privacy/vendor review, delegate low-risk owned-asset approvals, and report median/90th-percentile cycle time, coverage, overdue findings and assessor-account expiry monthly. High-risk and personal-data work keeps mandatory gates.



Task 11 Defend the framework under changed requirements

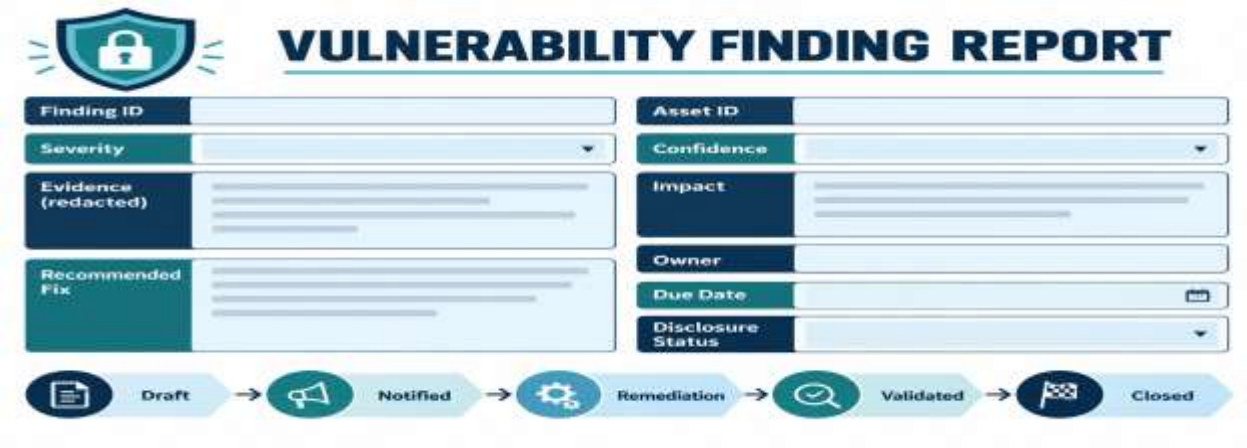
Component	Decision and adaptation
Authorization register	Retain; add recurring schedule, owner recertification, assessor identity and automatic expiry.
RoE	Master programme RoE plus per-cycle exact asset/method/window appendix; each run activated separately.
Privacy/legal	Add classification, residency/vendor check, current commencement review and privacy gate.
Disclosure	Accelerate: critical ≤1h to leadership; high ≤4h; others ≤1 business day; daily critical review.

Third parties	Contract, NDA, training, named personnel, least privilege, evidence location, deletion and offboarding.
Continuous checks	Run on approved lab/staging; production automation requires separate authorization, monitoring and stop controls.

New component: Continuous Assessment Change Gate

Each run has a run ID linked to current scope, RoE, owner confirmation and assessor. Before launch, check data classification, expiry, change freeze and active incident. If any check fails, skip and route to a human approver. Findings enter the same restricted register and faster disclosure queue. Third parties receive time-bound credentials and cannot change scope or publish findings.

FLOW	FLOW	FLOW	FLOW	FLOW
Scope + authority current?	Privacy/vendor gates current?	No freeze or incident?	YES → bounded run	NO → skip + approval



Defence, trade-offs and future work

The walkthrough demonstrates the redirect boundary; legal mapping shows owner approval does not settle provider or data duties; the disclosure process assigns deadlines; scale comparisons explain central metrics. Together, these controls preserve traceability without treating a recurring schedule as standing permission.

Trade-off / limitation	Mitigation / improvement
More gates can slow routine work	Track cycle time; parallelize and delegate low-risk university-owned work.
Fixed disclosure clocks may not suit vendor releases	Severity-based deadlines, documented extension and harm review.
Lab differs from production	Use sanitized staging replicas and disclose environment limitations.
Actor intent is uncertain	Record conduct and authorization separately; do not rely on labels for response.

Operational note: timelines and thresholds are proposed internal targets, not statutory safe harbors. The university must validate legal applicability, contracts, policy and operational capacity before adopting them.



Conclusion

The framework makes authority and scope verifiable, connects ethics and law to controls, contains practical work in an isolated lab, and routes findings to remediation and controlled disclosure. It is ready for university review after validating current law, asset ownership, approval delegations and incident contacts.

References

1. India Code, Information Technology Act, 2000 (updated text): https://www.indiacode.nic.in/bitstream/123456789/13116/1/it_act_2000_updated.pdf
2. MeitY, Digital Personal Data Protection Act, 2023: https://www.meity.gov.in/writereaddata/files/Digital%20Personal%20Data%20Protection%20Act%202023.pdf
3. MeitY, commencement notification G.S.R. 843(E), 13 Nov 2025: https://www.meity.gov.in/static/uploads/2025/11/c56ceae6c383460ca69577428d36828b.pdf
4. U.S. Code, 18 U.S.C. §1030: https://uscode.house.gov/us/usc/119-134/t18/s1030/
5. Course rubric: CO1_Assignment_1.docx, ITA1439 Ethical Hacking.